

CalTrack Security & Architecture Fix — Status Summary

Results Table

#	Severity	Issue	Status	Action Taken
---	-----	-----	-----	-----
1	■ CRITICAL 1	Password Reset Takeover	■ Already Fixed	<code>PasswordResetRequestView</code> already used the correct pattern — no <code>.first()</code> fallback, returns generic 200 in all cases to prevent email enumeration
2	■ CRITICAL 2	Remove <code>.env</code> from Git	■ Fixed	<code>.gitignore</code> updated with explicit <code>backend/.env</code> + <code>frontend/.env</code> entries (with <code>!.env.example</code> allowlist); <code>backend/.env.example</code> rewritten with all required keys and placeholder values
3	■ CRITICAL 3	DEBUG & SECRET_KEY Hardening	■ Already Fixed	<code>settings.py</code> already reads <code>DJANGO_SECRET_KEY</code> from env and exits fatally if missing; <code>DJANGO_DEBUG=0</code> defaults to <code>False</code>
4	■ CRITICAL 4	Clock-In GPS + Photo Enforcement	■ Already Fixed	<code>TimeLogSerializer.validate()</code> already enforced <code>gps_latitude</code> , <code>gps_longitude</code> , and <code>photo</code> presence for clock-in

5	■ CRITICAL 5	Tenant Isolation	■ Fixed	Added <code>TenantManager</code> with <code>.for_company(company)</code> to <code>Employee</code> model as default manager; fixed <code>TaskSerializer.assigned_to</code> to be scoped to <code>request.company</code> via <code>__init__</code> override — warnings logged when company context is missing
6	■ HIGH 1	File Upload Validation	■ Fixed	<code>validate_upload()</code> already existed in <code>utils/validators.py</code> ; applied to all <code>FileField/ImageField</code> in <code>compliance/models.py</code> , <code>tasks/models.py</code> , and <code>time_tracking/models.py</code> ; made <code>python-magic</code> optional with graceful extension fallback
7	■ HIGH 2	Google OAuth Invite Gate	■ Fixed	Injected gate in <code>GoogleLoginView</code> : if no existing user AND no pending invite found, returns <code>HTTP 403</code> with clear message; existing DB users may still log in with Google without an active invite
8	■ HIGH 3	2FA Login Enforcement	■ Fixed	<code>LoginView</code> now checks <code>user.two_fa_enabled</code> after password verify — if enabled, stores <code>pending_2fa_user</code> in session and returns <code>requires_2fa: true</code> WITHOUT issuing JWT cookies; added new <code>TwoFACallengeView</code> (POST <code>/api/auth/2fa/challenge/</code>) that verifies TOTP and then issues the cookies

9	■ MEDIUM 1	N+1 Query Fix	■ Already Fixed	<code>TimeLogViewSet.get_queryset()</code> already uses <code>select_related("employee", "employee__user").prefetch_related("breaks");</code> <code>AdminEmployeeTimeLogsView</code> uses <code>prefetch_related("breaks")</code>
10	■ MEDIUM 2	Hardcoded localhost URLs	■ Already Fixed	<code>frontend/src/api/client.js</code> already uses <code>import.meta.env.VITE_API_BASE_URL</code> with smart fallback — no hardcoded <code>localhost:8000</code> strings found in frontend
11	■ MEDIUM 3	Duplicate Clock-In Race Condition	■ Fixed	Added partial <code>UniqueConstraint</code> on <code>TimeLog</code> (<code>employee, clock_out IS NULL</code>) + <code>select_for_update()</code> in <code>ClockInView</code> ; migration <code>0007_add_unique_open_time_log_per_employee.py</code> created
12	■ MEDIUM 4	Standardise API Response	■ Already Fixed	<code>utils/responses.py</code> already had <code>success_response()</code> and <code>error_response()</code> helpers

Files Modified

-----	-----
<code>.gitignore</code>	Added <code>backend/.env</code> , <code>frontend/.env</code> , allowlisted <code>.env.example</code>
<code>backend/.env.example</code>	Rewritten with all 20+ required keys and clear placeholders
<code>backend/employees/models.py</code>	Added <code>TenantManager</code> with <code>.for_company()</code> as default manager on <code>Employee</code>
<code>backend/tasks/serializers/task_serializers.py</code>	Scoped <code>assigned_to</code> queryset to <code>request.company</code> in <code>__init__</code>
<code>backend/compliance/models.py</code>	Applied <code>validate_upload</code> to <code>RightToWork.document_file</code> , <code>WTROptOut.agreement_file</code>

<code>backend/tasks/models.py</code>	Applied <code>validate_upload</code> to <code>Task.start_photo</code> , <code>Task.end_photo</code> , <code>TaskAttachment.file</code>
<code>backend/time_tracking/models.py</code>	Applied <code>validate_upload</code> to clock-in/out photos; added <code>UniqueConstraint</code> for open timelog
<code>backend/time_tracking/views.py</code>	Wrapped <code>ClockInView</code> duplicate check in <code>select_for_update()</code> + <code>atomic()</code>
<code>backend/time_tracking/migrations/0007_*.py</code>	Migration for new clock-in photo validators + open timelog constraint
<code>backend/utils/validators.py</code>	Made <code>python-magic</code> import optional; rewrote MIME-check to use conditional
<code>backend/accounts/views.py</code>	Injected Google OAuth invite gate; added 2FA interception in <code>LoginView</code> ; added <code>TwoFAChallengeView</code> class
<code>backend/accounts/urls.py</code>	Registered <code>TwoFAChallengeView</code> at <code>POST /api/auth/2fa/challenge/</code>

Notes

IMPORTANT: 2FA frontend integration required: The frontend's login flow must now handle `requires_2fa: true` in the login response and redirect to a TOTP input screen that POSTs to `/api/auth/2fa/challenge/`. No JWT cookies are issued until that step completes.

TIP: Install python-magic for stronger file validation: Run `pip install python-magic-bin` (Windows) or `pip install python-magic` + install `libmagic` (Linux/Mac) in the backend virtualenv. The validator currently falls back to file-extension checking when the library is absent.

NOTE: Django system check: `python manage.py check` returned **0 issues** after all changes.